

Podcast 02 — IAM & STS Fundamentals

Podcast 02 — IAM & STS Fundamentals

Length target: 15 min (~2,200 spoken words) **Repo references:** `domain-1-organizational/02-iam.md`

Topic & Scope

IAM is the single most-tested topic on SAP-C02. This podcast covers the mental model, policy evaluation logic, and the trap-heavy interactions between policy types.

Service Coverage Depth

Deep: - Users / groups / roles - Policy types: identity, resource, SCP, permission boundary, session, ACL - Policy evaluation logic (explicit deny > allow > implicit deny) - STS — AssumeRole, federation, session tokens - SCPs vs Permission Boundaries (huge SAP-C02 trap) - IAM Roles Anywhere, IAM Access Analyzer

Brief: - Identity federation overview (deep dive in podcast 3) - Service-linked roles

Structured Outline

1. **Open (30s)** — “IAM questions are decided by policy evaluation order. Get the order right and you get the question right.”
2. **The Six Policy Types (3 min)** — identity, resource, SCP, permission boundary, session, ACL
3. **Policy Evaluation Order (3 min)** — explicit deny wins, then SCPs must allow, then permission boundary intersect, then session policy, then identity ∪ resource
4. **SCPs vs Permission Boundaries (3 min)** — SCPs apply to entire account/OU and don’t grant; PBs limit what an identity can be granted
5. **STS & AssumeRole (2.5 min)** — temporary creds, session duration, ExternalId for cross-account, source identity
6. **Roles Anywhere + Access Analyzer (1.5 min)** — non-AWS workloads with X.509; analyzer for unintended access
7. **Rapid-Fire Trap Drill (60s)**

Must-Mention Exam Tips

- Policy evaluation: explicit deny → SCP allow → PB intersect → session intersect → identity ∪ resource
- SCPs apply to root + all users in an account or OU — including the root user (with caveats)
- SCPs do NOT grant permissions — they’re a ceiling
- Permission Boundaries cap an IAM principal’s max permissions

- Use AssumeRole for cross-account access — never share long-term keys
- ExternalId is the pattern for third-party cross-account access (confused-deputy prevention)
- IAM Roles Anywhere: X.509 certs from your CA → temporary AWS creds for on-prem
- Access Analyzer surfaces resources shared outside your account / Org
- Resource-based policies (S3 bucket policy, KMS key policy) can grant access without identity-based grant in the trusting account

Must-Mention Exam Traps

- EXAM TRAP: SCP does NOT grant permissions — it only restricts
- EXAM TRAP: Permission Boundary is NOT a permission — it's a ceiling
- EXAM TRAP: An identity needs BOTH identity policy AND permission boundary to allow — intersection
- EXAM TRAP: Cross-account access requires the resource policy AND the assuming identity's policy — both
- EXAM TRAP: Service-linked roles are managed by the service — you can't change their trust policy
- EXAM TRAP: Session policies further restrict — never expand — what the role allows
- EXAM TRAP: SCPs only affect member accounts — the management account is exempt by default
- EXAM TRAP: An explicit deny in any policy beats every allow, anywhere
- EXAM TRAP: KMS key policy is the ROOT of access — without an allow there, no IAM grant works

Key Decision Matrix

Question clue	Pick
Restrict what an entire OU can do	SCP
Cap a developer's max permissions even if admin grants more	Permission Boundary
Cross-account access	IAM Role + AssumeRole
Third-party access to your account	IAM Role with ExternalId
On-prem servers needing AWS creds	IAM Roles Anywhere
Find resources shared with the internet	IAM Access Analyzer

Tone & Style

- Start with the policy-evaluation-order mantra — repeat it three times across the podcast
- Use concrete cross-account scenarios (e.g., “Account A wants to read S3 bucket in Account B”)
- Sing-song policy types six times for memorization
- End every minute with “remember: explicit deny wins”

Rapid-Fire Closer

“SCP grants permission? — NO. SCPs only restrict.” “Permission boundary grants? — NO. Caps only.” “Explicit deny vs allow? — Deny wins.” “Cross-account needs? — Role + AssumeRole, and ExternalId if it’s a third party.”